

PROCUREMENT RISK ASSESSMENT REPORT

DICT Procurement of AWS Cloud Hosting for eGovernment Digital Platforms

Invitation to Bid No. DICTBAC-2026-005 | Approved Budget: ₱362,969,397.00
Prepared by: Technical Working Group (TWG) Supporting the BAC of DICT | Date: April 28, 2026

Members:

Section: 3 WMAD 2

Apao, John Lloyd E.

Cristal, Princess Ashlie D.

Molina, Jan Michael B

PART I — Risk Identification

The table below identifies eight (8) major risk categories for the AWS Cloud Hosting procurement. Each risk is assessed by possible scenario, impact level, likelihood, and recommended mitigation control.

Risk Category	Possible Risk	Impact	Likelihood	Mitigation Recommendation
Financial Risk	Budget overrun due to AWS usage-based pricing; currency fluctuation (PHP/USD); underestimated compute needs.	High	Medium	Require fixed-price or capped subscription model; set budget alerts; engage independent cost estimator; include penalty clauses for overruns.
Vendor Lock-in Risk	Heavy reliance on AWS-specific services (Lambda, RDS, S3) making future migration costly or impractical.	High	High	Adopt cloud-agnostic architectures (Kubernetes, open standards); include data portability and exit clauses in contract; require migration plan.
Cybersecurity Risk	Unauthorized access, DDoS attacks, insider threats,	High	High	Mandate ISO 27001 / FedRAMP compliance; require WAF, IDS/IPS, MFA, encryption at rest and in

Risk Category	Possible Risk	Impact	Likelihood	Mitigation Recommendation
	misconfigurations exposing sensitive eGovernment data.			transit; conduct penetration testing quarterly.
Data Privacy Risk	Personal data of Filipino citizens stored on foreign servers may violate Republic Act 10173 (Data Privacy Act).	High	Medium	Require data residency in Philippine AWS region (AP-Southeast-1 or local); include NPC-compliant DPA; conduct PIA before go-live.
Service Availability Risk	AWS regional outages, network disruptions, or maintenance windows causing government service downtime.	High	Medium	Require minimum 99.99% SLA; mandate multi-AZ/multi-region deployment; define RTO ≤ 4 hours, RPO ≤ 1 hour in contract.
Compliance Risk	Non-compliance with RA 10173 (Data Privacy Act), RA 8792 (e-Commerce Act), DICT Cloud Policy, or GPPB IRR.	High	Medium	Include mandatory compliance attestations; require regular third-party audits; assign DICT compliance officer to oversee contract performance.
Disaster Recovery Risk	Lack of tested DR plan; data loss during AWS zone failure; insufficient backup frequency for critical systems.	High	Low	Require documented and tested DR/BCP plan; daily automated backups; quarterly DR drills; off-cloud backup copies maintained independently.
Procurement Fraud Risk	Bid rigging, tailored technical specs favoring AWS, undisclosed conflicts of interest in TWG, collusion among bidders.	High	Low	Open and competitive bidding process; independent TWG members; COA oversight; publish all bid documents publicly; require integrity pacts.

Legend: **HIGH** **LOW**

PART II — Risk Assessment Questions

A. Technical Risks

Key technical risks in cloud hosting include:

- Service outages caused by regional AWS failures or network disruptions affecting eGovernment portals and citizen-facing services.
- Performance degradation from misconfigured autoscaling, insufficient bandwidth, or database bottlenecks under peak load (e.g., tax season, election services).

- Data corruption or loss due to poorly designed backup schedules or unvalidated restore procedures.
- Software vulnerabilities in unpatched operating systems, containers, or third-party libraries hosted on AWS infrastructure.

Impact of an outage on eGovernment services:

- Citizens cannot access critical services (e.g., PhilSys, GOVPH, eGov portals), causing public frustration and reputational damage to DICT.
- Businesses relying on government APIs for permits, licenses, and compliance submissions will face operational disruptions.
- Revenue-generating government processes (e.g., online payment of taxes and fees) will halt, causing direct financial losses.

High Availability (HA) / Disaster Recovery (DR) controls recommended:

- Multi-AZ (Availability Zone) deployment within AWS AP-Southeast-1 (Singapore) or future PH region for redundancy.
- Active-active or active-passive failover configurations with automatic health check routing via AWS Route 53.
- Daily incremental and weekly full backups stored in a separate AWS S3 bucket with versioning and cross-region replication.
- Documented DR plan with Recovery Time Objective (RTO) $\leq$ 4 hours and Recovery Point Objective (RPO) $\leq$ 1 hour, tested quarterly.

B. Security Risks

Security threats to consider:

- Unauthorized access via compromised credentials or over-permissioned IAM roles.
- DDoS attacks targeting public-facing eGovernment endpoints.
- Data exfiltration by malicious insiders or external threat actors exploiting misconfigured S3 buckets or open ports.
- Man-in-the-middle attacks on data in transit due to improper TLS/SSL configuration.
- Supply chain attacks through vulnerable third-party libraries or AWS Marketplace products.

Mandatory security requirements for the contract:

- ISO/IEC 27001 certification for the cloud provider and its authorized resellers.
- Web Application Firewall Intrusion Detection and Prevention System (IDS/IPS), and DDoS protection (AWS Shield Standard minimum).
- Encryption at rest and in transit for all government data.
- Mandatory use of AWS CloudTrail for audit logging and AWS Config for compliance monitoring.
- Quarterly vulnerability assessment and penetration testing (VAPT) by a COA-accredited third party.

IAM risk reduction strategies:

- Enforce least-privilege principle no IAM role shall have broader permissions than required.
- Mandatory Multi-Factor Authentication (MFA) for all privileged accounts.
- Regular IAM access reviews (monthly) and automated alerts for unused or anomalous permissions.
- Separation of duties: development, staging, and production environments under separate IAM accounts/OUs.

C. Procurement Risks

Verifying contract reasonableness:

- Conduct an independent cost benchmark against AWS public pricing, GPPB price indices, and comparable government cloud contracts (e.g., DBM, PSA, DOH AWS deals).
- Engage an independent ICT consultant to validate the Approved Budget for the Contract (ABC) of ₱362,969,397.00 against projected workloads.
- Require the winning bidder to submit a detailed cost breakdown, including compute, storage, network, and support tiers.

Vendor lock-in indicators to watch:

- Technical specifications that exclusively reference proprietary AWS services (e.g., mandating AWS Lambda, Amazon Aurora, AWS Kinesis) with no vendor-neutral equivalents allowed.
- Absence of data portability guarantees or exit provisions in the draft contract.
- Long contract terms (3–5 years) without meaningful performance review and exit milestones.

Risks during bidding and implementation:

- Bid rigging: BAC members or TWG advisors with undisclosed financial ties to AWS authorized resellers.
- Technical specification tailoring to exclude qualified competitors (e.g., Microsoft Azure, Google Cloud).
- Collusion among the limited pool of AWS resellers accredited by the Philippine government.
- Implementation delays caused by migration complexity, insufficient DICT technical staff capacity, or inadequate change management.
- Scope creep leading to contract amendments that push total cost well beyond the ₱362.97M ABC.

PART III — Risk Matrix Exercise

Risk Score = Probability × Impact. Scale: 1 (Lowest) to 5 (Highest). Priority thresholds: Critical ≥ 15, High 8–14, Medium 4–7, Low 1–3.

Risk Scenario	Probability (1–5)	Impact (1–5)	Risk Score (P×I)	Priority Level	Classification
Cloud Service Outage	3	5	15	CRITICAL	Immediate Action
Data Breach	3	5	15	CRITICAL	Immediate Action
Budget Overrun	4	4	16	CRITICAL	Immediate Action

Risk Scenario	Probability (1–5)	Impact (1–5)	Risk Score (P×I)	Priority Level	Classification
Vendor Lock-in	4	4	16	CRITICAL	Immediate Action
SLA Failure	3	4	12	HIGH	Priority Action
Compliance Violation	2	5	10	HIGH	Priority Action

Observations:

- Cloud Service Outage and Data Breach both score 15 — CRITICAL priority. These must be addressed as pre-conditions before contract award.
- Budget Overrun and Vendor Lock-in score 16 — CRITICAL. The large contract value (₱362.97M) amplifies financial exposure.
- SLA Failure scores 12 — HIGH. Rigorous SLA monitoring mechanisms and penalty clauses are essential.
- Compliance Violation scores 10 — HIGH. Given Philippine data privacy law requirements, non-compliance poses legal and reputational risk.

PART IV — BAC Decision Scenario

TWG Recommendation: APPROVE WITH ADDITIONAL CONTROLS

Justification:

The procurement of AWS Cloud Hosting for DICT eGovernment platforms at ₱362,969,397.00 is technically justified given the Philippine government's digital transformation agenda under the Bagong Pilipinas program. However, the TWG identifies several material risks — particularly vendor lock-in, data privacy, cybersecurity, and budget overrun — that cannot be left unaddressed prior to contract award. Outright rejection is not warranted as there is no evidence of procedural violation, and re-bidding would cause costly delays to critical public services. Approval with additional controls is the most prudent course of action.

Conditions of Approval the following safeguards must be incorporated into the contract before signing:

- Mandatory SLA of 99.99% uptime with financial penalties for breaches; quarterly performance reviews.
- Data residency clause requiring all Philippine citizen data to remain within AWS AP-Southeast-1 or a future Philippine AWS region.
- Data Privacy Act compliance attestation and signing of a Data Processing Agreement (DPA) compliant with NPC Circular 2023-04.
- Exit and data portability clause: upon contract end, DICT must receive all data in open, vendor-neutral formats within 30 days at no additional cost.
- Independent annual financial and technical audit by COA-accredited auditors.
- Budget monitoring mechanism: AWS Cost Explorer dashboards accessible to DICT-BAC; monthly cost reports submitted by the contractor.
- Integrity Pact signed by all bidders and BAC members before bidding closes.
- Require the contractor to present a tested DR/BCP plan within 60 days of contract effectivity.

PART V — Summary & Safeguards

This Procurement Risk Assessment Report was prepared by the Technical Working Group (TWG) of DICT for Invitation to Bid No. DICTBAC-2026-005. The assessment covers eight risk categories across financial, cybersecurity, legal, operational, and governance dimensions. All identified risks are classified and addressed through specific mitigation controls and contract conditions. The TWG recommends approval with additional controls as detailed in Part IV.

BONUS CHALLENGE — Cloud Strategy Recommendation

Recommendation: Multi-Cloud Strategy (AWS Primary + Microsoft Azure/GCP Secondary)

Defense:

- Avoids single-vendor dependency the most significant risk in this procurement. A multi-cloud approach distributes workloads across at least two providers, eliminating catastrophic single-provider lock-in.
- Resilience: in the event of an AWS regional outage, critical eGovernment workloads (PSA, PhilSys, GOVPH) can failover to Azure or GCP environments, meeting strict RTO/RPO requirements.
- Competitive pricing: maintaining active multi-cloud relationships ensures DICT can renegotiate AWS pricing at renewal, as the government retains the credible option to migrate.
- Alignment with international best practice: the UK Government Cloud Framework, US FedRAMP, and the EU Cloud Strategy all endorse multi-cloud to reduce vendor dependency for critical public infrastructure.
- Phased approach: Award this contract to AWS for the primary environment, but invest in containerized (Kubernetes/OpenShift) architecture that enables workload portability, and begin piloting secondary cloud environments in parallel.
- Limitation to acknowledge: Multi-cloud increases operational complexity and requires a larger pool of skilled DICT engineers. This must be addressed through capacity-building and training investments.

Reflection — Is Cloud Procurement More About Technology, Security, or Risk Management?

Cloud procurement for government is fundamentally about risk management with technology and security as critical sub-components within that broader framework.

Technology is the enabler: it defines what is possible, what infrastructure is needed, and how services will be delivered. Security is the constraint: it defines the boundaries within which government data can be trusted and citizen privacy protected. But risk management is the governing discipline that determines whether a procurement should proceed, on what terms, and with what safeguards.

The DICT AWS case illustrates this clearly. The technology (AWS cloud) is mature and capable. The security requirements (ISO 27001, encryption, IAM, VAPT) are well understood. Yet the most critical decisions whether the ₱362.97 million budget is justified, whether vendor lock-in is acceptable, whether

Philippine data privacy law is satisfied, whether the procurement process was transparent are all fundamentally risk management questions, not technology questions.

In government contexts, the stakes are amplified: public funds are involved, citizen data is at risk, and public trust is on the line. A technically excellent cloud solution procured without proper risk management can become a financial disaster, a security breach, or a legal liability. Risk management therefore serves as the integrating discipline that makes both technology adoption and security controls meaningful and accountable in public sector procurement.